



AGL Assessment Automation (AAA) の紹介

May 25, 2026

Takashi Ninjouji (Honda R&D),

Hiroyuki Ishii (Panasonic Automotive Systems)

Who we are

Takashi Ninjouji



- Chief Engineer, Honda R&D, Honda OSPO
- AGL, Lead of this initiative
- OpenChain, SPDX
- LinkedIn: [takashi-ninjouji](#)

Hiroyuki Ishii



- OSS Community Expert, Panasonic Automotive Systems
- Linux Foundation Japan Evangelist
- AGL Steering Committee
- Kernel, Yocto, Tracing, Virtualization, OSPO
- LinkedIn: [hiroyuki-ishii-059b11134](#)

背景:なぜ自動車業界で SBOMが重要なのか

大規模なソフトウェア開発

- SBOMの自動生成なしでは、全ソフトウェア構成要素のリスク管理は極めて困難

複雑でレガシーなサプライチェーン

- 多層的なサプライチェーンの管理には、共通のデータ形式と業界共通のプラクティスが不可欠

規制 & コンプライアンス (あくまで例)

- UNECE WP.29 R155/R156, ISO/SAE 21434, ISO 24089
- US E.O. 14028, EU CRA, BIS ICTS
- ISO/IEC 5230, ISO/IEC 18974

※参考:[Complying With Regulatory SBOM Requirements Using the Yocto Project \(Joshua Watt, OSSNA 2026\)](#)

Automotive Grade Linux (AGL)

- Linux Foundation傘下の非営利団体
- Linuxベースのオープンソースプロジェクト
- Unified Code Base (UCB) : 車載向けオープンプラットフォーム (IVI、クラスター、テレマティクス等)
 - ビルドシステム/ベースディストリビューションとしてYoctoを利用
- 自由にカスタマイズ可能、認証不要 (Androidとの差別化要素)
- [SoDeV](#) : Xen、Zephyr、ELISAなどのOSSプロジェクトと連携加速、オートモーティブ以外の産業からも注目を集める

AGL Assessment Automation (AAA)

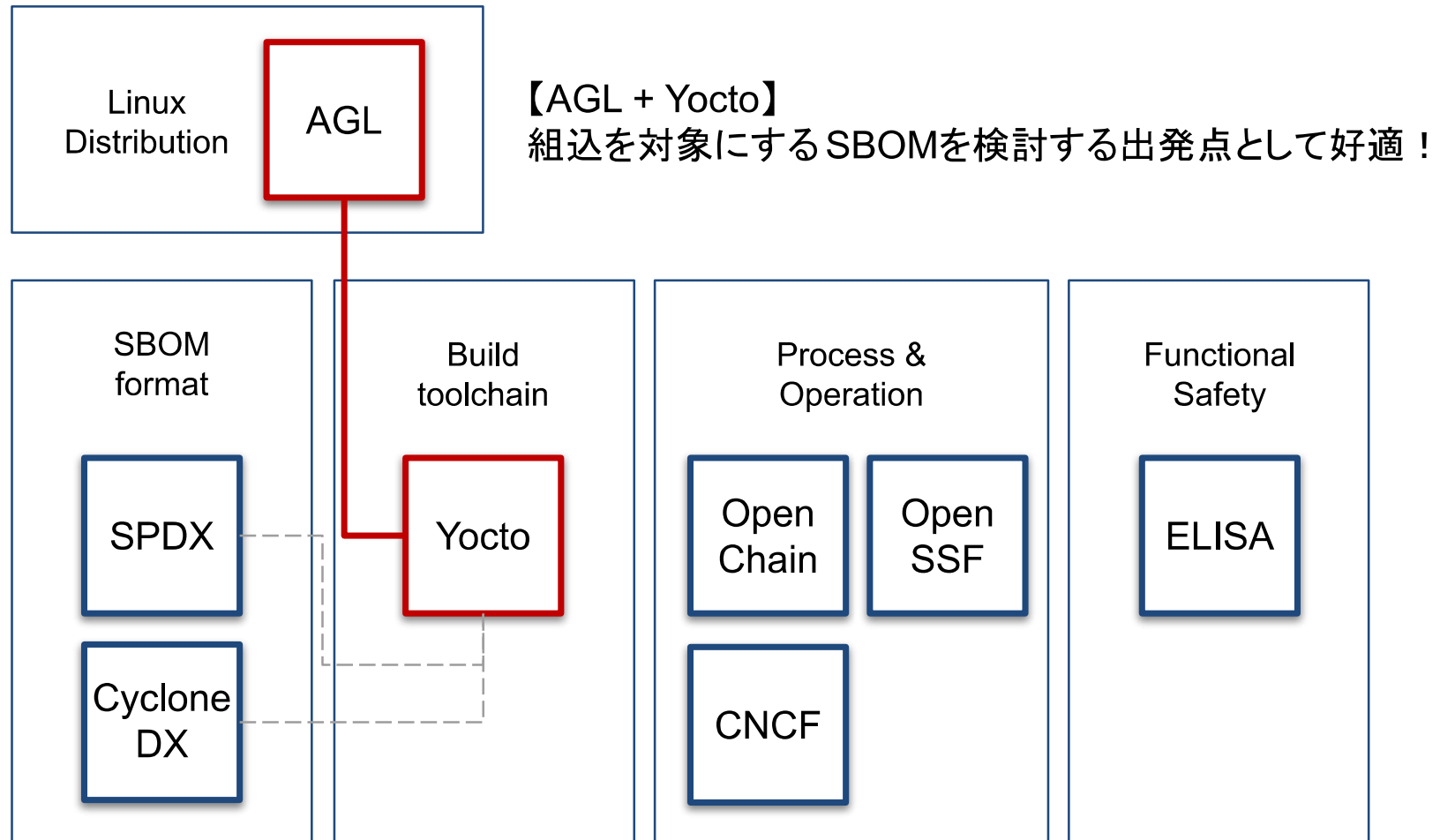
目的

- 自動車・組込み向けに、SBOMオペレーションのリファレンスシステムとベストプラクティスを構築・共有

フォーカス

- AGLのCIシステム上で、ポリシーベースの評価自動化を検証
- OpenSSFやCNCFのサイバーセキュリティ・ベストプラクティスを可能な限り採用
 - SBOM Lifecycle、SLSA など
- SPDX 3.0 JSON (Yocto対応) をターゲットとする
- オープンソースコミュニティ(Yocto、OpenSSF、OpenChain、SPDX等)と連携
- オープンソースかつ再利用可能なツールチェーンを活用

SBOMオペレーションのベストプラクティスを探る



Improving Risk Management Decisions with SBOM Data

OpenSSF, 2025/9

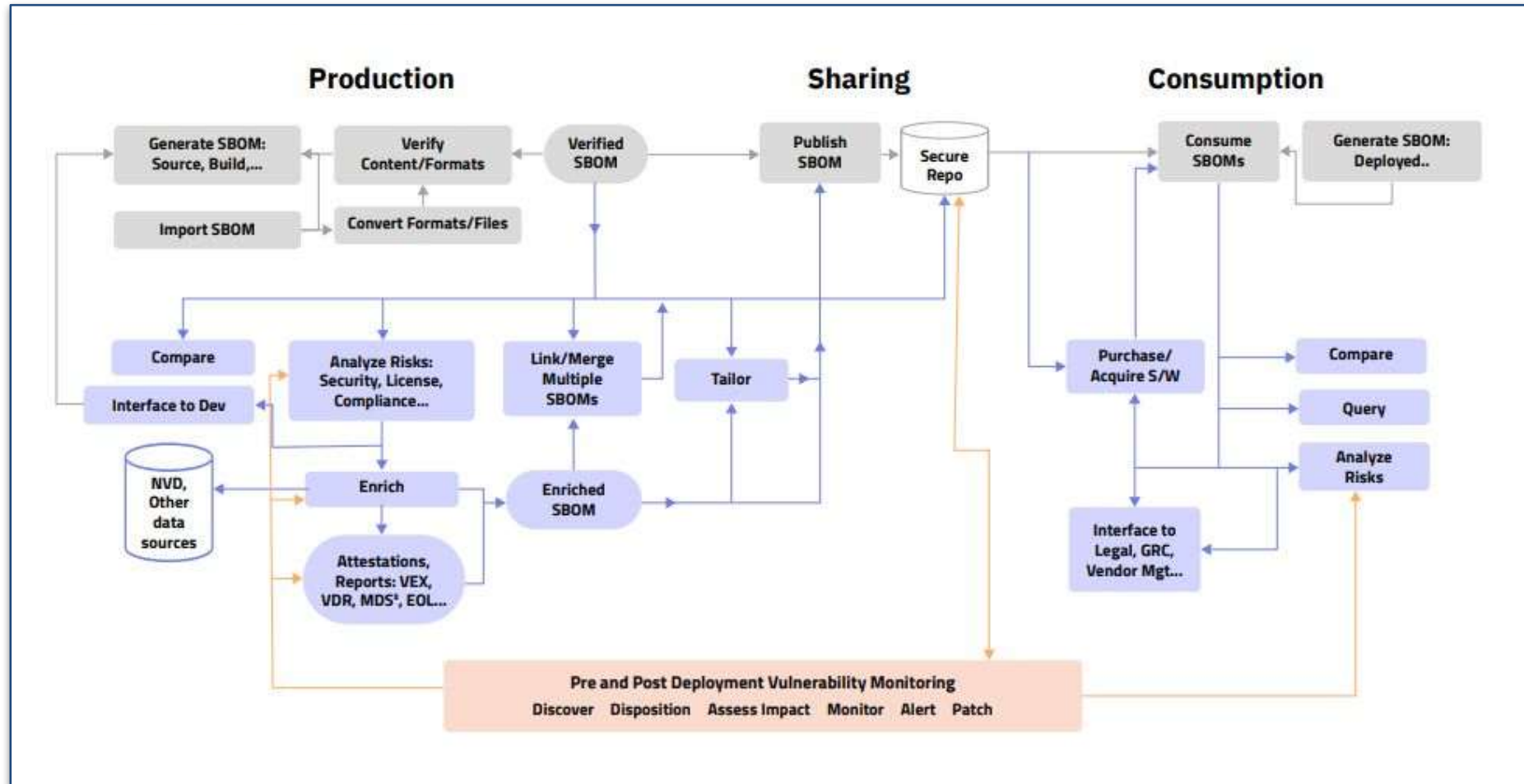
- CISA主導の SBOM Operations Tiger Team が起草
→ OpenSSF SBOM Everywhere SIG が完成して公開
- SBOM Lifecycle を Production / Sharing / Consumption の3フェーズに分解し、
13のユースケースや成熟度モデルを定義

ユースケースの代表例 (車載や組込にも)

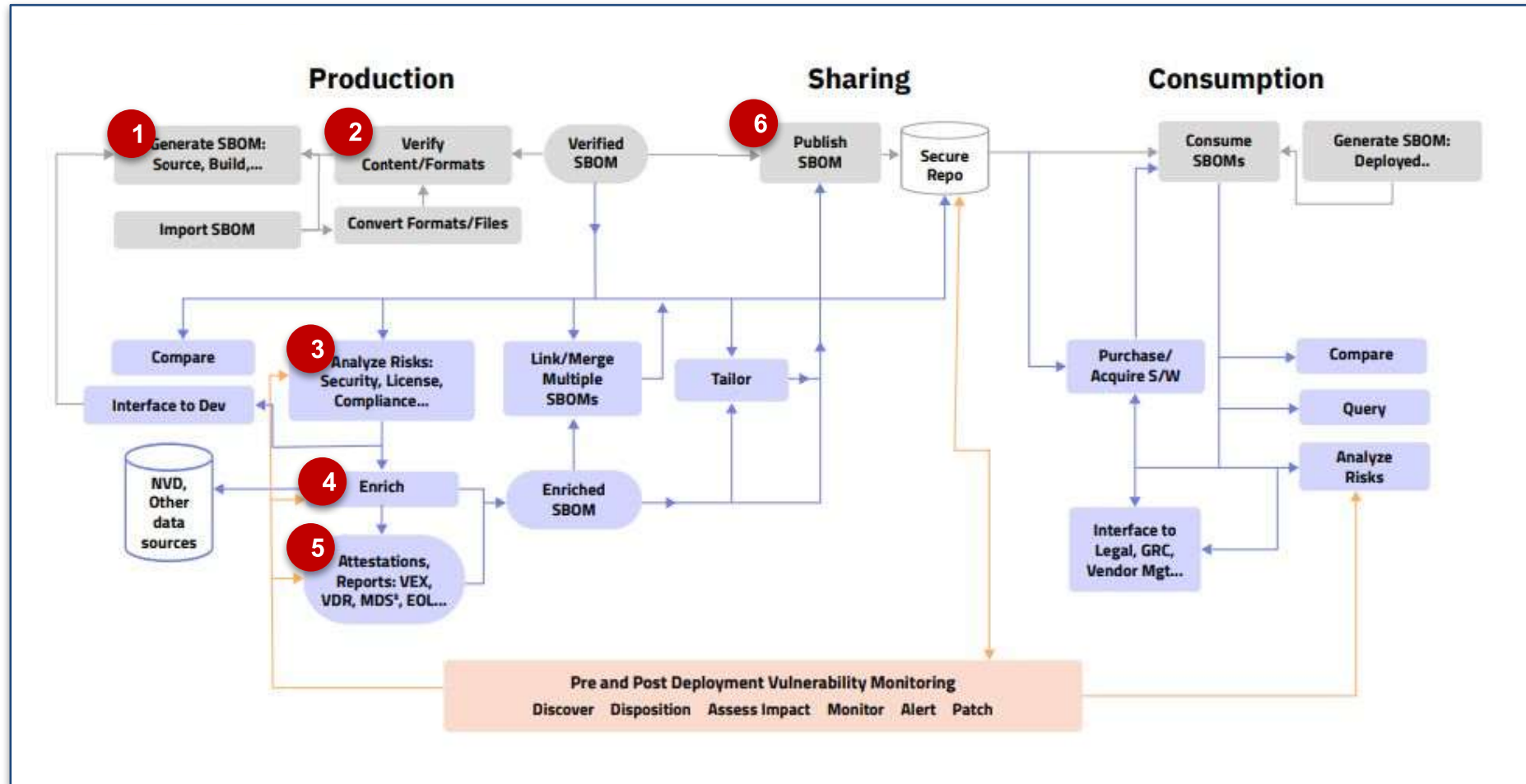
- 脆弱性管理: SBOM × CVE/VEX で本当に影響を受けるCVEに絞り、対応を加速
- EOL/EOSコンポーネントの検出(車両のサポート期間中の保守に直結)
- ライセンスコンプライアンス、インシデント対応の高速化、リリース判断



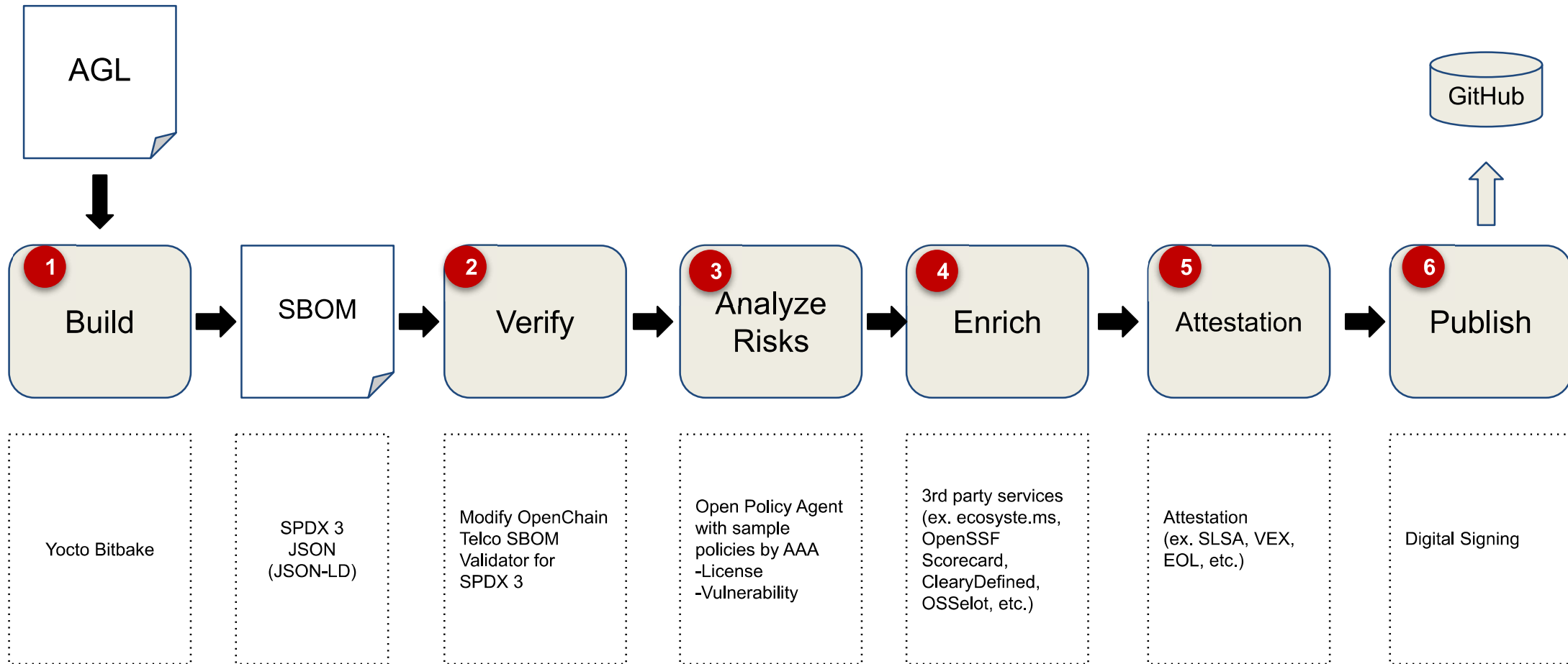
SBOM Lifecycle Diagram に基づくプロセスの自動化を検証



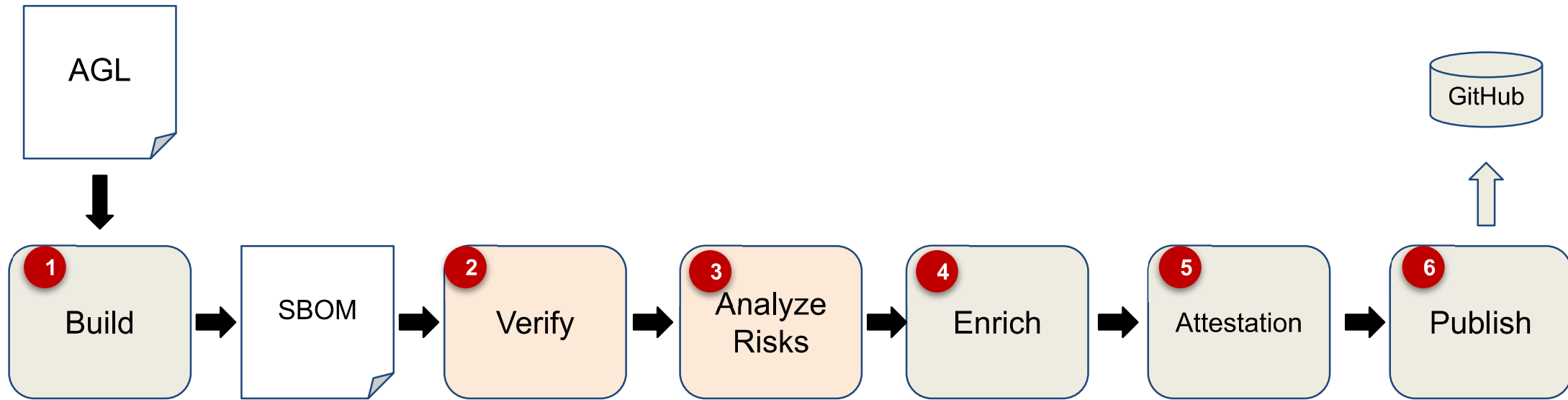
まずはベストケースの事例を作ってみるところから



Pipeline example



Pipeline example



PoC: Verify

SPDX 3 JSON の validation tool が少ない(2026年1月時点)

➡ そこで、PoCとしてシンプルな validator を実装

Tool	SPDX Spec version	Profile / Scope
Telco SBOM Validator	SPDX 2.2, 2.3	OpenChain Telco SBOM Guide 1.1
NTIA conformance checker	SPDX 2.2, 2.3, 3.0	NTIA 2021, FSCT3 (minimum)
Sbomqs	SPDX 2.2, 2.3	BSI TR-03183-2 (v1.1 & v2.0), FSCT v3, OpenChain Telco, NTIA

2026年5月追記:

1. SPDX-Python-model の開発が進んでいる。Validator 実装を移行するかも
(<https://github.com/spdx/spdx-python-model>)
2. Microsoft / sbom-tool も SPDX 3 対応が進んでいる
(<https://github.com/microsoft/sbom-tool>)

PoC: Verify

AGL UCB から生成した Yocto の SPDX 3 SBOM を検証

- 全体的な品質は概ね良好 (OpenChain Telco SBOM Guide に基づく評価)
- Yocto コミュニティで改善が継続中 (例: PURL対応)

```
python3 sdx_tree_viewer.py /home/ubu/depot/automation-playground/example-sboms/spdx3.0/agl-image-minimal-qemux86-64.rootfs-20251125004622.spdx.json --scope-summary
```

```
=====
LifecycleScopedRelationship Summary by Scope
=====

Total LifecycleScopedRelationships: 2860
Scopes: 2

-----
Scope           Rels   Packages   Files
-----
build           2537    452        630
runtime         323     205         0
-----
```

```
Requirements Summary:
-----
Requirement                                           Status
-----
SPDXVersion provided?                                True
DataLicense provided?                                False
DocumentName provided?                              True
Creator provided?                                    True
Created timestamp provided?                          True
SBOM Type provided?                                  True
All PackageNames provided?                          True
All PackageVersions provided?                        False (279/452)
All PackageSuppliers provided?                       False (0/452)
All PackageDownloadLocations provided?               False (172/452)
All PackageCopyrightTexts provided?                  False (0/452)
All PackageLicenseConcluded provided?                 False (0/452)
All PackageLicenseDeclared provided?                 False (451/452)
At least one license is not NOASSERTION?             False (171/452)
All PackageChecksums provided? (RECOMMENDED)         False (142/452)
All Package URLs (PURL) provided? (RECOMMENDED)      False (0/452)
Runtime dependency relationships exist?               True
All dependency targets exist as Package?             True
Transitive dependencies complete?                    True
Missing components as known unknowns?               True
-----

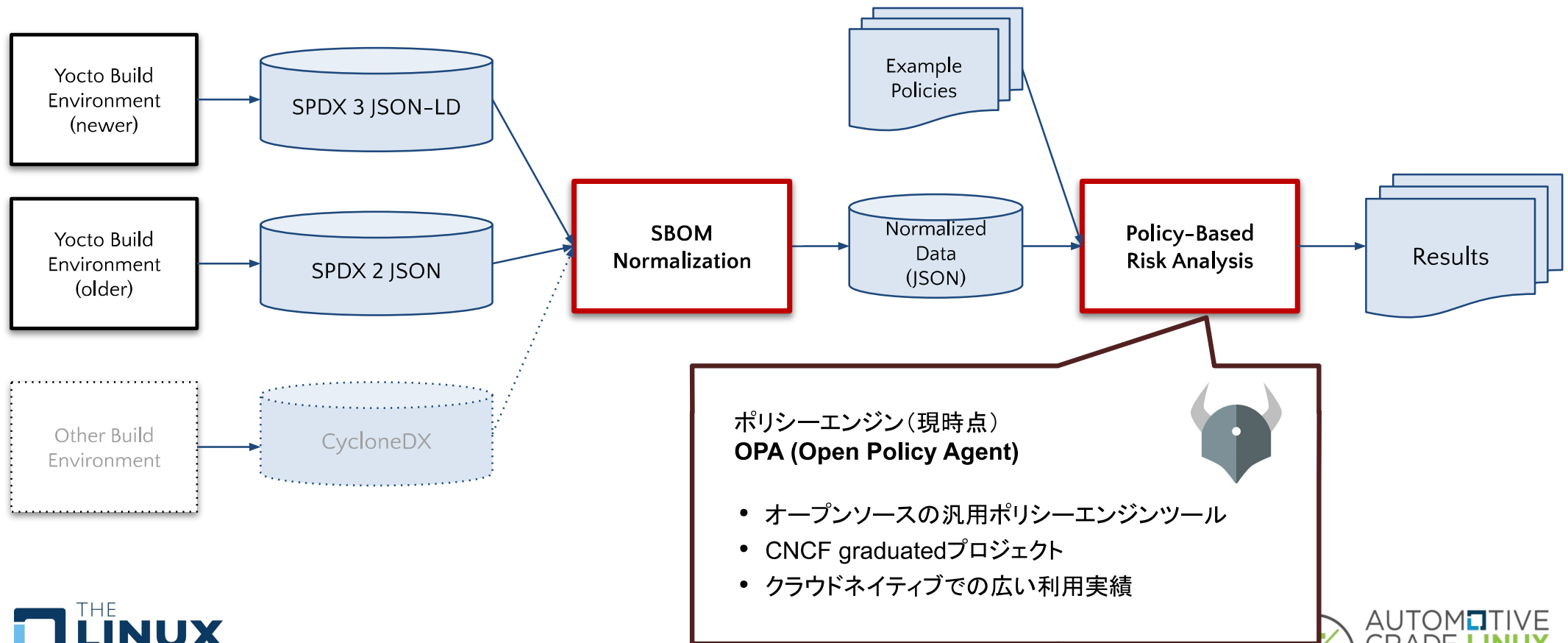
Mandatory Requirements: 10/18
Recommended Requirements: 0/2
Violations: 2199
Warnings: 800
```

Note: As of Sep. 2025 (Yocto 5.2)

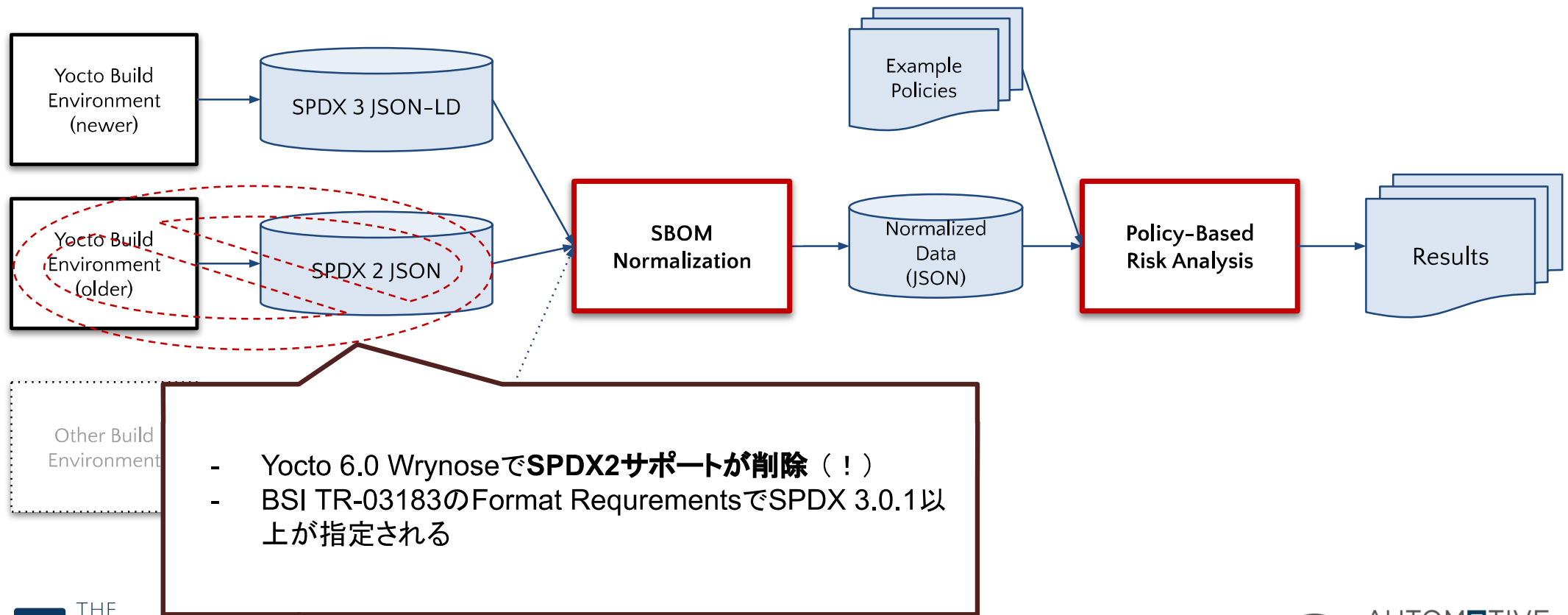
2026年5月追記: Yocto 6.0 Wrynose

1. PURL対応拡充: cargo_common, go-mod, pypi, npm, cpan*
2. CI/CD Traceability: SPDX_INVOKED_BY 他

PoC: Analyze Risks



PoC: Analyze Risks



Example Policies

Example Policy 1: Detecting GPL v3 Family Licenses

Policy Code:

```
package license

licenses_gplv3_family := [
    "GPL-3.0-only",
    "GPL-3.0-or-later",
    "LGPL-3.0-only",
    "LGPL-3.0-or-later",
    "AGPL-3.0-only",
    "AGPL-3.0-or-later",
]

banned_license_gplv3[res] {
    some i
    pkg := input.packages[i]
    license_string := pkg.license_declared

    not_is_invalid_license(license_string)
    license_tokens := tokenize_spdx(license_string)
    license_to_check := license_tokens[_]
    contains(licenses_gplv3_family, license_to_check)
}

res := {
    "0:message": sprintf("%s is banned by project: GPLv3 Family", [license_to_check]),
    "1:pkgName": pkg.name,
    "2:pkgVersion": pkg.version,
    "3:license": license_string
}
```

Input JSON:

```
"packages": [
  {
    "name": "base-files",
    "version": "3.0.14",
    "license_declared": "GPL-2.0-only",
    "license_concluded": ""
  },
  {
    "name": "base-passwd",
    "version": "3.6.7",
    "license_declared": "GPL-2.0-only",
    "license_concluded": ""
  },

```

Result:

```

build@UN690:/home/ishit/depot/agl/automation_work/automation_playgrounds$ opa eval --format=json \
  ty --data policy/license.rego --input data/spdx3_agl-image-weston_normalized.json data.license \
  banned_license_gplv3
[
  {
    "0:message": "GPL-3.0-only is banned by project: GPLv3 Family",
    "1:pkName": "tar",
    "2:pkgVersion": "1.35",
    "3:license": "GPL-3.0-only"
  },
  {
    "0:message": "GPL-3.0-or-later is banned by project: GPLv3 Family",
    "1:pkName": "kbd-keymaps-pine",
    "2:pkgVersion": "2.8.0",
    "3:license": "GPL-3.0-or-later"
  },
  {
    "0:message": "GPL-3.0-or-later is banned by project: GPLv3 Family",
    "1:pkName": "libreadline8",
    "2:pkgVersion": "8.3",
    "3:license": "GPL-3.0-or-later"
  }
]

```

Example Policy 2: Admin Check for Unknown Licenses

Base Policy:

```

licensees_gsi_approved := [
    "BSD",
    "AAL",
    "AFL-1.1",
    "AFL-1.2",
    "AFL-2.0",
    "AFL-2.1",
    "AFL-3.0",
    "AGPL-3.0",
    "AGPL-3.0-only",
    "AGPL-3.0-or-later",
    "APL-1.0",
    "APSL-1.0",
    "APSL-1.1",
    "APSL-1.2",
    "APSL-2.0",
    "Apache-1.1",
    "Apache-2.0",
    "Artistic-1.0",
    "Artistic-1.0-Perl",
    "Artistic-1.0-cl8",
    "Artistic-2.0",
    "BSD-1-Clause",
    "BSD-2-Clause",
    "BSD-2-Clause-Patent",

```

Product Specific Policy:

```
licenses_project_approved := [
    "BSD-4-Clause-UC",
]
```

+

```

not_approved_license[res] {
    some i
    pkg := Input.packages[i]
    license_string := pkg.license_declared

    not is_invalid_license(license_string)
    license_tokens := tokenize_spdx(license_string)

    license_to_check := license_tokens[i]
    not contains(licenses_osi_approved, license_to_check)
    not contains(licenses_project_approved, license_to_check)

res := {
    "0:message": sprintf("%s is neither approved by OSI nor project", [license_to_check]),
    "1:pkgName": pkg.name,
    "2:pkgVersion": pkg.version,
    "3:license": license_string
}
}

```

Result:

```
build@ubuntu:~/home/ish1/depot/agl/automation/work/automation-playgrounds$ opa eval --format-pretty --data policy/license.rego --input data/spdx3_agl-image-weston_normalized.json data.license.not_approved_license

{
  "0:message": "FTL is neither approved by OSI nor project",
  "1:pkgName": "libfreetype",
  "2:pkgVersion": "2.13.3",
  "3:license": "( FTL OR GPL-2.0-or-later ) AND MIT"
}

{
  "0:message": "GPL-1.0-or-later is neither approved by OSI nor project",
  "1:pkgName": "util-linux-swaponoff",
  "2:pkgVersion": "2.41.1",
  "3:license": "GPL-1.0-or-later AND GPL-2.0-only AND GPL-2.0-or-later AND LGPL-2.1-or-later AND BSD-2-Clause AND BSD-3-Clause AND BSD-4-Clause-UC AND MIT AND EUPL-1.2"
}

{
  "0:message": "HPND-sell-variant is neither approved by OSI nor project",
  "1:pkgName": "libixbcompose-data",
  "2:pkgVersion": "1.8.4",
  "3:license": "MIT AND BSD-1-Clause AND HPND AND HPND-sell-variant AND ISC"
}

{
  "0:message": "HPND-sell-variant is neither approved by OSI nor project",
  "1:pkgName": "libxbcommon0",
  "2:pkgVersion": "1.11.0",
  "3:license": "MIT AND MIT-open-group AND HPND AND HPND-sell-variant AND X11"
}
```

BSD-4-Clause-UC was approved

フィードバックやヒント - OpenChain and Friends (ドイツ, 2026/03)

- 欧州コミュニティの印象
 - 産業やサプライチェーン構造が日本と似ており、課題や関心、必要とするソリューションの共通性が高い
- フィードバック
 - Yocto SBOM活用プラクティスプラクティス高いへの高い関心の声 (OCCTET)
「古いYoctoを使い続ける必要がある」など課題感も一致
- ヒント
 - Eclipse Aporpsis、OCCTET、OpenChainによるORT (Open source Review Toolkit) の活用

[Open Source based SupplyChain Management at scale | Nikola Babadzhanov \(Bosch\)](#)

[CRA tooling for SMEs by the OCCTET project | Martin von Willebrand \(DoubleOpen\)](#)

フィードバックやヒント - Open Source Summit NA (北米, 2026/05)

- 北米コミュニティの印象
 - CNCF、OpenSSF(、AAIF)による強力な推進力。組み込み特有の課題を的確に打ち込み、巻き込んでいけるかがポイント。
-
- ヒント
 - Enrichフェーズでのキュレーションデータベース活用 (Github+ClearlyDefined)
 - ✓ OSADL OSSelotなどの競合プロジェクトと比較評価必要
 - OSPOワークフローでのAI活用事例 (TODO Group, 他多数)

[Introducing the Agentic AI to Empower OSPOs Working Group | TODO Group // Talk openly, develop openly](#)

[Open Source Summit + Embedded Linux Conference North America 2026: Scaling Your OSPO With Agents and Automa...](#)

次のアクション

ポリシーエンジン再評価 : OPA (Open Policy Agent) vs ORT (OSS Review Toolkit)

- 評価軸: SPDX3対応, ポリシー柔軟性, パイプライン, プラクティス, エコシステム, ...

CVE/VEX オペレーション

- ~~eve-check~~, yocto-vex-check, sbom-cve-check, VulnScout, ...

その他

- SLSA in AOSP: [Open Source Summit NA 2026: Verification Toward Applying SLSA in Automotive IVI Software Development - Yuta Kiyoumi & Takashi Ninjouji, Honda Motor](#)
- キュレーションデータベース活用
- AI活用

Thank you!

Repository:

<https://github.com/automotive-grade-linux/automation-playground>



Confluence:

[English](#)

[Japanese](#)

Discord:

<https://discord.gg/ZztCaVeQVG>

